

INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

GRC102 - INFORMATION SECURITY GOVERNANCE

PRACTICAL LABORATORY 8 / WEEK 5 LINUX LAB

Simulating and Analysing Security Governance Scenarios

Monitoring, Auditing Controls and Executive Reporting

Author	Kefilwe Matake
Registration Number	C11_26_CGRCE_17575
Course	GRC102 - Information Security Governance
Role	Security Governance Analyst
Environment	Authorised isolated Ubuntu / Docker simulation

Associated Evidence Report

Executive Summary

This report documents an authorised, isolated security-governance simulation modelled on governance failures associated with the 2017 Equifax breach. The evidence package demonstrates the intended governance lifecycle: establish a vulnerable baseline, identify governance weaknesses, implement governance controls, and communicate posture through metrics and executive reporting.

The strongest evidence in the submitted package is the governance configuration and state data: an intentionally vulnerable Docker design, a governance tracker with policies, controls, risks, incidents and metrics, a generated governance-failure report identifying four control-governance weaknesses, control implementation records, governance oversight documentation, and an executive reporting package. The evidence also contains important internal inconsistencies that must be treated as assurance findings rather than hidden. In particular, the authoritative governance tracker still shows a Critical and a High risk as Open, while the board report states that no Critical or High risks remain. The patch-status artifact contains only the MySQL security state, and the historical trend charts are simulation-generated rather than measured production history.

Evidence Coverage Summary

Requirement	Primary evidence	Status	Assurance interpretation
Part 1 - Environment	docker-compose.yml; governance_data.json; governance tracker scripts	Available	Baseline environment and governance state can be evidenced.
Part 1 - Vulnerability scan	Standalone vulnerability_report_*.json	Available	Scanner logic runtime report attached.
Part 2 - Failure analysis	governance_failure_report_20261007_195441.json; equifax_comparison.md	Available	Four governance failures are directly evidenced.
Part 2 - Attack simulation	simulate_attack.py; attack_log.json	Partial	Simulation script supplied; attack_log.json not available.
Part 3 - Control implementation	implement_governance_controls.py; governance_controls_report.md; governance_data.json; patch_status.json; governance_oversight.md	Available	Implementation records exist; verification evidence available
Part 4 - Metrics & reporting	governance_metrics.py; governance_metrics_framework.md; executive_dashboard.html; board_report.md; dashboard_user_guide.md; five trend charts	Available	Reporting package is complete as a simulation, subject to data-provenance caveats.

Report Structure

1. Part 1 - Setting Up a Simulated Environment
2. Part 2 - Analysing Security Governance Failures
3. Part 3 - Implementing Security Governance Controls
4. Part 4 - Developing Security Governance Metrics and Reporting
5. Overall Governance Assessment and Recommendations
6. References and Evidence Index

Part 1 - Setting Up a Simulated Environment

The lab environment was designed to reproduce governance conditions similar to the Equifax case study. The Docker Compose configuration defines three services on an isolated Docker network: a vulnerable Apache Struts web application, a MySQL 5.7 customer-data service, and an Ubuntu monitoring service. The web application exposes port 8080 to the lab host, while all three containers share the secgov_network.

1.1 Environment Architecture

Service	Image	Purpose	Governance relevance
web_server	vulhub/struts2:s2-045	Intentionally vulnerable customer-facing application	Demonstrates exposure created by delayed patching.
database_server	mysql:5.7	Synthetic customer-data store	Uses lab credentials to illustrate weak authentication and data-layer risk.
monitoring_server	ubuntu:20.04	Monitoring / evidence service	Provides a location for security-monitoring logic and control evidence.

```
services:
  web: vulhub/struts2:s2-045 -> web_server -> 8080:8080
  database: mysql:5.7 -> database_server
  monitoring: ubuntu:20.04 -> monitoring_server
network: secgov_network (external / isolated lab network)
```

1.2 Baseline Governance State

Governance object	Count	Evidence summary
Policies	4	Patch, vulnerability, incident response and governance oversight policies.
Controls	8	Eight controls are recorded, including five 2026 governance improvements.
Risks	3	1 Critical, 1 High and 1 Medium risk; all three remain recorded as Open.
Incidents	1	One historical high-severity web-server compromise is recorded.
Metrics	5	Five metrics, including pre-improvement and October 2026 measures.
Audits	1	One external annual security audit record.

1.3 Baseline Risk and Metrics

ID	Risk	Level	Status	Planned treatment
RISK-001	Unpatched Vulnerabilities	Critical	Open	Automated patch management
RISK-002	Insufficient Network Segmentation	High	Open	Network segmentation / least privilege
RISK-003	Weak Authentication	Medium	Open	Multi-factor / strong authentication

Metric	Target	Actual	Period	Interpretation
Patch Compliance	95%	85%	May 2023	Below target
Vulnerability Remediation Time	7 days	12 days	May 2023	Worse than target

Metric	Target	Actual	Period	Interpretation
Security Incidents	0	1	May 2023	Above target
Critical Patch Compliance	100%	100%	Oct 2026	Simulation reports target met
Security Monitoring Coverage	100%	100%	Oct 2026	Simulation reports target met

1.4 Part 1 Assessment

The supplied configuration is suitable for an isolated governance simulation because it deliberately combines a vulnerable internet-style application tier, a sensitive data tier and a monitoring tier, docker configuration and governance records.

Part 2 - Analysing Security Governance Failures

Governance-failure analysis identified four evidence-backed governance weaknesses. These findings are more important than isolated technical defects because they show where policy, ownership, architecture and measurement failed to produce effective risk reduction.

2.1 Governance Failure Analysis

Category	Finding	Governance impact	Recommended response
Policy Implementation	Patch Management Policy not effectively implemented	Critical vulnerabilities remain unpatched despite policy	Improve patch management process and oversight
Metrics and Measurement	Security metrics not driving effective remediation	Metrics not leading to security improvements	Implement actionable metrics with clear ownership and accountability
Security Architecture	Insufficient network segmentation	Potential for lateral movement and expanded compromise	Implement network segmentation according to least privilege principle
Authentication and Access Control	Weak database authentication	Potential for unauthorized database access	Implement strong authentication and access controls for databases

2.2 Attack Simulation Evidence

The attack-simulation script is designed to send a controlled request to the vulnerable Struts service, determine whether the lab application responds as vulnerable, and, only within the isolated simulation, create an attack_log.json record representing data access. The evidence includes the simulation script but no resulting attack log file. For this reason, the final report does not claim a successfully executed attack as verified evidence.

2.3 Comparison with the Equifax Breach

The lab deliberately mirrors well-documented Equifax governance failures. NIST records CVE-2017-5638 as a critical Apache Struts remote-code-execution vulnerability with a CVSS 3.1 base score of 9.8. The U.S. Government Accountability Office (GAO) found that the Equifax breach was facilitated by failures in vulnerability identification, detection, network segmentation and data governance. The House Oversight Committee also identified weak accountability and management structure as a major governance factor.

Governance theme	Equifax lesson	Simulation parallel	Similarity
Patch / vulnerability management	The affected Struts instance remained unpatched after public notification.	Lab uses an intentionally vulnerable Struts image and records patch-governance failure.	High
Monitoring / detection	Expired monitoring certificate prevented inspection of encrypted traffic.	Lab requires monitoring and metrics to detect control failure.	High
Network segmentation	GAO found lack of database segmentation enabled wider access.	Lab identifies insufficient segmentation and lateral-movement risk.	High
Authentication / data governance	Attackers obtained credentials enabling access to additional databases.	Lab identifies weak database authentication.	Medium
Accountability / policy execution	House report found unclear authority and execution gaps.	Lab identifies policy implementation and metrics not driving remediation.	High

The key governance lesson is that policies and technology controls do not reduce risk unless ownership, evidence, monitoring and escalation convert them into action. The simulation demonstrates the same principle: a patch policy can exist while a critical risk remains open; a metric can exist while remediation is not completed; and technical architecture can remain permissive unless decision rights and validation are explicit.

Part 3 - Implementing Security Governance Controls

The control implementation phase added five governance improvements to the tracker: automated patch management, network segmentation, database security, real-time security monitoring and executive security oversight. The associated governance report states that these controls were implemented and verified. The evidence was therefore reviewed at two levels: implementation evidence and independent verification evidence.

3.1 Implemented Controls

Control	Name	Owner	Control objective
CTL-004	Automated Patch Management	Security Engineer	Patch identification, testing and timely critical remediation
CTL-005	Network Segmentation	Network Engineer	Reduce unnecessary lateral connectivity
CTL-006	Database Security	Database Administrator	Strengthen authentication and database access control
CTL-007	Real-time Security Monitoring	Security Engineer	Detect suspicious activity and generate alerts
CTL-008	Executive Security Oversight	CEO	Formalise executive / board oversight and escalation

3.2 Governance Oversight Model

The governance oversight artifact assigns ultimate governance responsibility to the CEO, day-to-day security-program responsibility to the CISO, IT-infrastructure security responsibility to the CIO and security-budget responsibility to the CFO. It also introduces quarterly Board security briefings, an annual security-program review, a Board security committee, performance metrics and explicit escalation paths.

Role	Governance responsibility
CEO	Ultimate responsibility for security governance
CISO	Day-to-day security programme accountability
CIO	IT infrastructure security
CFO	Security budget governance
Board / Committee	Quarterly briefing, annual programme review, material oversight

3.3 Verification Assessment

Control area	Implementation evidence	Verification evidence	Assessment
Automated patch management	Control exists in <code>governance_data</code> ; implementation script records it.	<code>patch_status.json</code> does not contain <code>struts_patched</code> .	Partially verified
Network segmentation	Control exists and implementation script attempts PATCH-003.	<code>patch_status.json</code> does not contain <code>network_segmented</code> .	Partially verified
Database security	Control exists and implementation script attempts PATCH-002.	<code>patch_status.json</code> contains <code>mysql_secured=true</code> .	Verified at simulation-state level
Security monitoring	Control exists and the implementation script writes a monitor script and cron definition.	Generated monitoring files were not supplied separately.	Partially verified
Executive oversight	<code>governance_oversight.md</code> exists and POL-004/CTL-008 are recorded.	Documentary evidence is present.	Verified as governance design

3.4 Required Improvement to Control Verification

- Persist all control states in one structured record rather than overwriting the status file for each action.

- Retest each implemented control using an independent verification function and retain timestamped results.
- Update the risk register only after successful retest and formal risk-owner approval; do not leave remediated risks recorded as Open without explanation.
- Retain vulnerability-scan outputs, attack-simulation logs, monitoring alerts and configuration evidence as immutable evidence linked to the relevant control and date.
- Separate control implementation ownership from assurance approval where practical.

Part 4 - Developing Security Governance Metrics and Reporting

The reporting package contains a metrics framework, an executive HTML dashboard, a board report, a dashboard user guide and five trend visualisations. Together they demonstrate how technical control information can be translated into executive-level governance reporting.

4.1 Metrics Framework

Metric category	Examples	Governance question
Implementation	Patch compliance; monitoring coverage; policy compliance	Is the control deployed and enforced?
Effectiveness	Vulnerability remediation time; incidents; control effectiveness	Is the control reducing risk?
Efficiency	Security cost per employee; staffing ratio; automation level	Is the control programme sustainable?
Impact	Incident cost; business disruption; customer impact	What is the business consequence?

The framework also defines the attributes management needs for a usable metric: name, description, formula, target, data source, frequency, owner and audience. This is a strong governance design because it prevents metrics from being detached from accountability.

4.2 Executive Dashboard Snapshot

Metric	Dashboard current	Target	Displayed status
Patch Compliance	100.0%	95%	Green
Vulnerability Remediation Time	1.0 day	7 days	Green
Security Incidents	0	0	Green
Security Monitoring Coverage	100.0%	95%	Green
Policy Compliance	100.0%	95%	Green
Control Effectiveness	95%	Not separately evidenced	Green in dashboard

4.3 Trend Visualisations

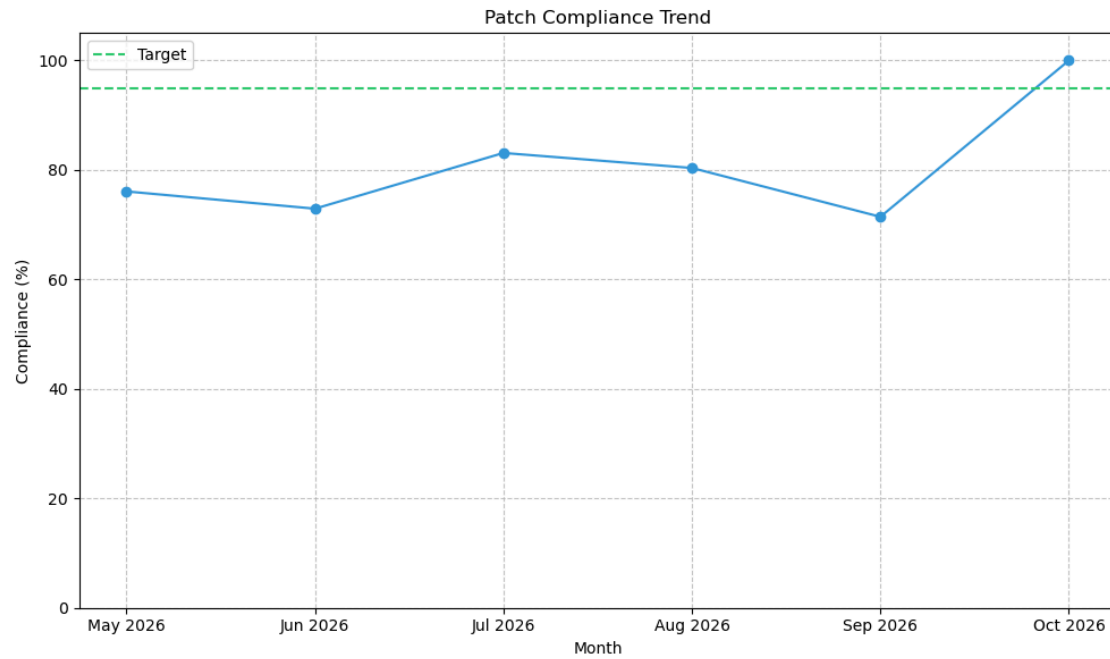


Figure 1. Patch Compliance Trend - simulation-generated lab metric. Target line: 95%.

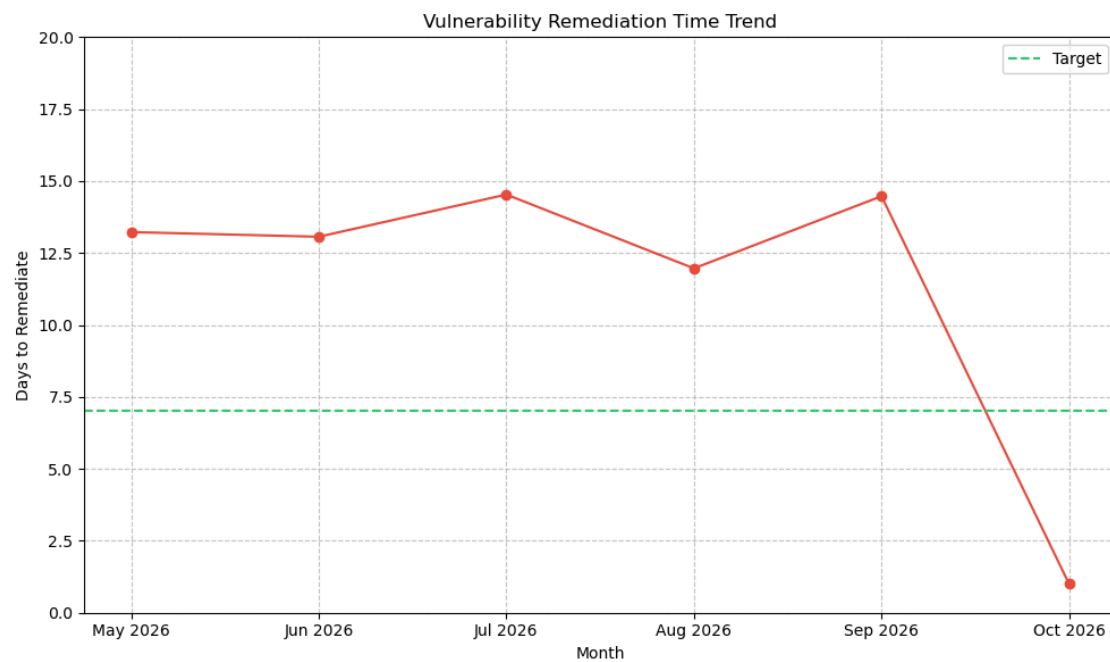


Figure 2. Vulnerability Remediation Time Trend - simulation-generated lab metric. Target line: 7 days.

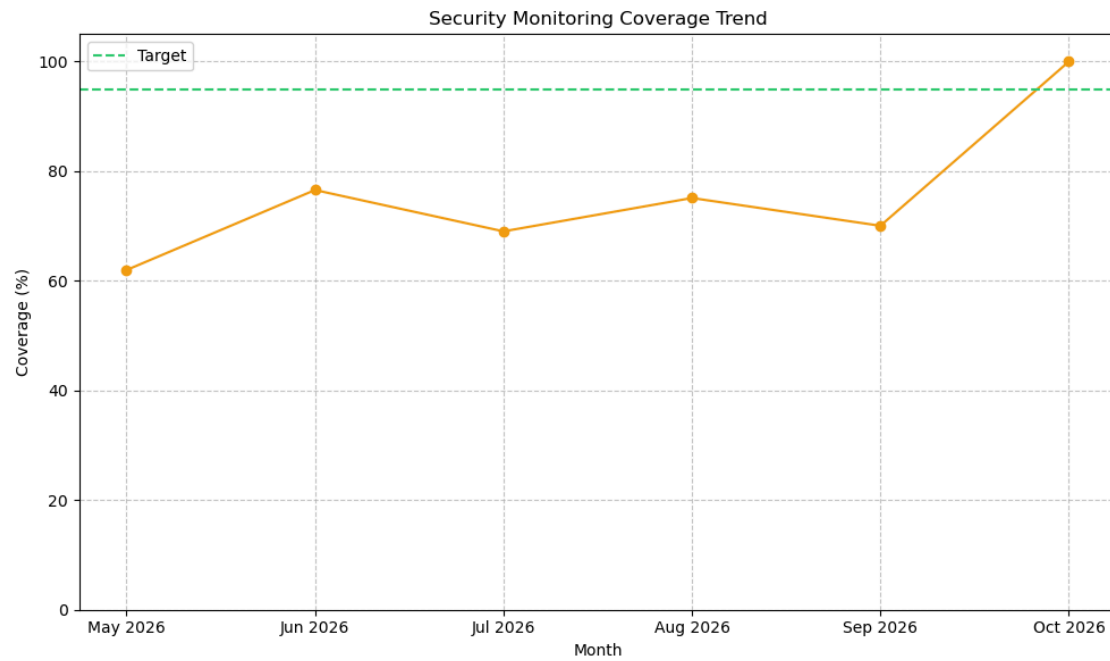


Figure 3. Security Monitoring Coverage Trend - simulation-generated lab metric. Target line: 95%.

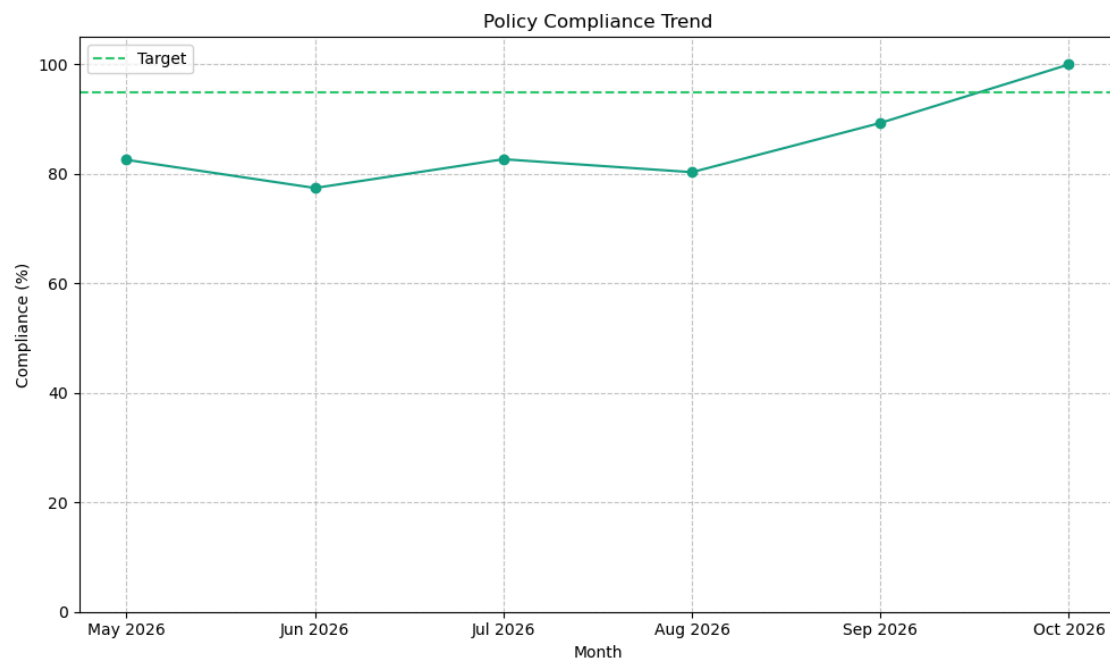


Figure 4. Policy Compliance Trend - simulation-generated lab metric. Target line: 95%.

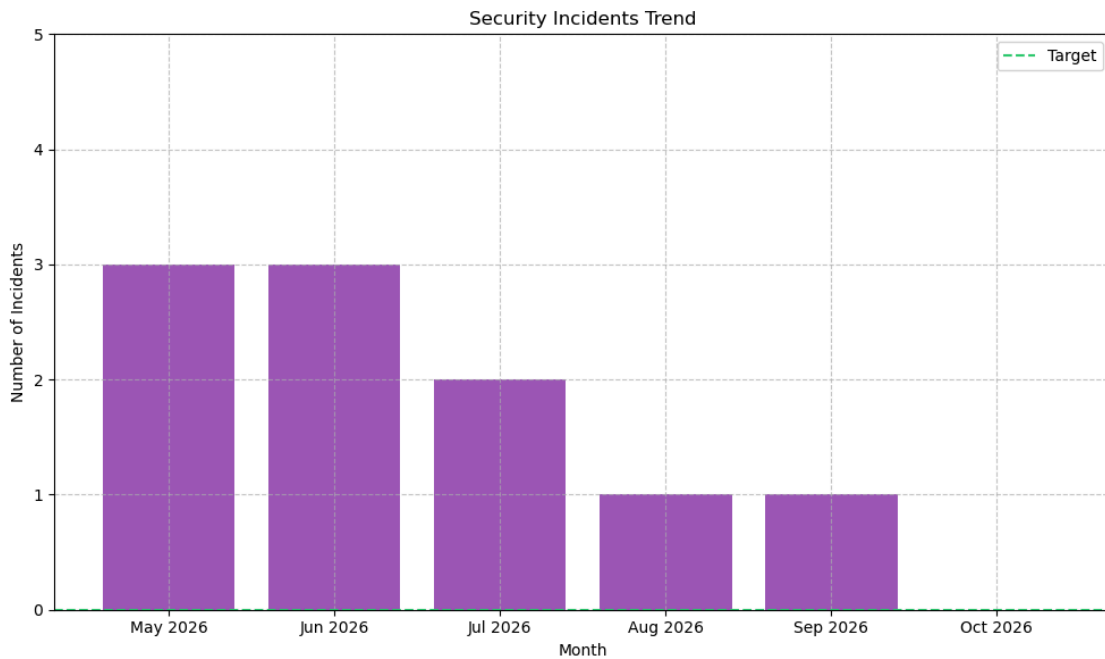


Figure 5. Security Incidents Trend - simulation-generated lab metric. Target: zero incidents.

4.4 Board Reporting and Data Consistency

The board report states that all key metrics meet or exceed targets and that there are no Critical or High risks. It also recommends continuing the governance programme, conducting independent assurance, improving awareness, developing third-party risk management and sustaining metrics reporting. These are appropriate executive-level themes. However, the authoritative `governance_data.json` still records RISK-001 as Critical/Open and RISK-002 as High/Open. Until those records are formally updated after independent retest, the board report should not state that zero Critical or High risks remain.

Source	Reported position	Evidence file	Assurance conclusion
Risk register	1 Critical, 1 High, 1 Medium - all Open	<code>governance_data.json</code>	Authoritative simulation state unless formally superseded
Board report	0 Critical, 0 High, 2 Medium, 3 Low	<code>board_report.md</code>	Presentation layer; conflicts with risk register
Executive dashboard	Overall posture Good; 0 Critical / 0 High	<code>executive_dashboard.html</code>	Presentation layer; not sufficient to close risks

4.5 Metrics and Reporting Governance Value

The metrics and reporting mechanisms support governance by making risk visible to different audiences. Operational teams need detailed findings and action items, executives need trend and threshold information, and the Board needs concise information on material risk, compliance and investment priorities. The strongest next step is to connect every dashboard value directly to an authoritative evidence source and prevent manually hard-coded or randomly generated values from being presented as verified control effectiveness.

Overall Governance Assessment and Recommendations

The lab successfully demonstrates the full security-governance cycle: a vulnerable baseline is established, governance failures are identified, controls are designed and recorded, and management reporting is produced. The evidence shows a sound understanding of the Equifax governance lessons, particularly the importance of patch management, monitoring, segmentation, authentication, accountability and actionable metrics.

From an assurance perspective, the simulation would be stronger if the technical evidence chain were made fully reproducible. The absence of a standalone vulnerability-report artifact and attack log, the patch-status overwrite problem, the continued Open state of Critical/High risks, and the use of simulation-generated trend values mean that the reporting layer is more mature than the underlying assurance trail. These are valuable findings because governance is not only about implementing controls; it is also about proving, through consistent evidence, that the controls operated and that risk decisions were formally closed.

Priority Recommendations

#	Recommendation	Required action	Owner	Timing
1	Fix evidence-state persistence	Store all patch/control states together; preserve timestamp and control ID.	Security Engineering	Immediate
2	Complete independent retesting	Retest Struts patching, segmentation, DB access and monitoring before risk closure.	Security Assurance	Immediate
3	Reconcile risk register and dashboard	Board/dashboard values must be sourced from the same authoritative risk data.	CISO / Risk	Before next report
4	Retain required runtime artifacts	Preserve vulnerability report, attack log, monitoring alerts and post-control scan.	Lab / Security Ops	Each test cycle
5	Make metrics direction-aware	For lower-is-better metrics (incidents, remediation days), status logic must not use actual >= target.	GRC / Metrics Owner	Next iteration
6	Replace random history for assurance use	Use recorded simulation events or explicitly label synthetic data.	GRC / Reporting	Next iteration

Final Conclusion

The submitted evidence demonstrates a credible governance simulation and a clear understanding of how technical weaknesses become management and Board issues. The lab particularly succeeds in linking technical controls to ownership, risk and reporting. The final assurance conclusion is therefore that the governance design is substantially developed, while the evidence-validation process still requires improvement before management could rely on the dashboard as proof of full control effectiveness. This conclusion is intentionally conservative and evidence-based.

References

- [1] U.S. Government Accountability Office (2018). Data Protection: Actions Taken by Equifax and Federal Agencies in Response to the 2017 Breach, GAO-18-559. <https://www.gao.gov/products/gao-18-559>
- [2] U.S. House Committee on Oversight and Government Reform (2018). The Equifax Data Breach. <https://oversight.house.gov/wp-content/uploads/2018/12/Equifax-Report.pdf>
- [3] National Institute of Standards and Technology, National Vulnerability Database. CVE-2017-5638 - Apache Struts Remote Code Execution. <https://nvd.nist.gov/vuln/detail/CVE-2017-5638>
- [4] ICDFA GRC102 Practical Laboratory instructions and assessment brief supplied with the course package.
- [5] Student-generated lab evidence files listed in the Evidence Index below.

Evidence Index

Evidence file	Part	Purpose
docker-compose.yml	Part 1	Docker environment definition
governance_data.json	Parts 1, 3, 4	Authoritative tracker state for policies, controls, risks, metrics and audit record
governance_tracker.py / initialize_governance.py	Part 1	Governance-tracker design and baseline initialization
analyze_governance_failures.py	Part 2	Failure-analysis logic
governance_failure_report_20261007_195441.json	Part 2	Four evidence-backed governance failures
simulate_attack.py	Part 2	Authorised attack-simulation logic; no attack_log.json supplied
equifax_comparison.md	Part 2	Initial case-study comparison, refined against public sources
implement_governance_controls.py	Part 3	Control implementation and verification logic
governance_controls_report.md	Part 3	Narrative implementation report
patch_management.py / patch_status.json	Part 3	Simulated patch actions and retained state
governance_oversight.md	Part 3	Executive / Board oversight design
governance_metrics.py	Part 4	Metric generation, visualisations, dashboard and board-report logic
governance_metrics_framework.md	Part 4	Metric categories, ownership and reporting framework
executive_dashboard.html	Part 4	Executive reporting output
board_report.md	Part 4	Board-level reporting output
dashboard_user_guide.md	Part 4	Dashboard use and interpretation guidance
Practical_Lab5_Assessment_Brief.docx - embedded charts	Part 4	Five submitted metric visualisations

AI Assistance Declaration

AI assistance was used to support report structure, language refinement, evidence reconciliation and source verification. The lab evidence, scripts, configuration files and generated outputs referenced in this report were supplied as student evidence. No missing runtime output was fabricated. The student remains responsible for understanding and validating all submitted technical and governance conclusions.